

# PinkSync Security Threats and Prevention Matrix

## 1. Sign Biometric Authentication Threats

| Threat                   | Description                                                  | Prevention Measures                                                                                                                                                                                                          | Detection Methods                                                                                                                                                                          | Response Plan                                                                                                                                                                                              |
|--------------------------|--------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Video Replay Attack      | Attacker presents recorded video of authorized user signing  | <ul style="list-style-type: none"><li>• Liveness detection (random challenge signs)</li><li>• Depth sensing technology</li><li>• Background variation detection</li><li>• Behavioral signature analysis</li></ul>            | <ul style="list-style-type: none"><li>• Motion consistency analysis</li><li>• Frame rate anomaly detection</li><li>• Background analysis</li><li>• Unexpected lighting changes</li></ul>   | <ul style="list-style-type: none"><li>• Immediate session termination</li><li>• Step-up to secondary authentication</li><li>• Record attempt details</li><li>• Notify user of attempt</li></ul>            |
| Deepfake Sign Videos     | AI-generated video mimicking authorized user's signing style | <ul style="list-style-type: none"><li>• Multi-factor biometric analysis (style, speed, facial features)</li><li>• AI-based deepfake detection</li><li>• Behavioral consistency checks</li><li>• Device attestation</li></ul> | <ul style="list-style-type: none"><li>• Micro-expression analysis</li><li>• Physics model violations</li><li>• Neural inconsistency patterns</li><li>• Anomalous signing fluency</li></ul> | <ul style="list-style-type: none"><li>• Progressive lockout</li><li>• Require in-person verification</li><li>• Flag account for additional monitoring</li><li>• Update deepfake detection models</li></ul> |
| Template Database Breach | Unauthorized access to biometric template storage            | <ul style="list-style-type: none"><li>• One-way template transformations</li><li>• Homomorphic encryption</li><li>• Template sharding across storage</li><li>• Key management system</li><li>• Template versioning</li></ul> | <ul style="list-style-type: none"><li>• Database access monitoring</li><li>• Anomalous query detection</li><li>• Template access audit logs</li><li>• Failed decryption attempts</li></ul> | <ul style="list-style-type: none"><li>• Emergency template invalidation</li><li>• User notification</li><li>• Force re-enrollment with new encryption</li><li>• Forensic investigation</li></ul>           |
|                          | Manipulating                                                 | <ul style="list-style-type: none"><li>• Adversarial training of</li></ul>                                                                                                                                                    | <ul style="list-style-type: none"><li>• Confidence score analysis</li><li>• Detection of</li></ul>                                                                                         | <ul style="list-style-type: none"><li>• Fallback to alternative auth method</li><li>• Model</li></ul>                                                                                                      |

|                                     |                                                 |                                                                                                                                              |                                                                                                                                |                                                                                                                                                       |
|-------------------------------------|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Adversarial Machine Learning</b> | input to confuse sign recognition models        | models<br>• Input sanitization<br>• Model ensemble approach<br>• Regular model updates                                                       | adversarial patterns<br>• Model disagreement monitoring<br>• Input preprocessing alerts                                        | quarantine and analysis<br>• Push emergency model update<br>• Record samples for future training                                                      |
| <b>Coercion Attack</b>              | Forcing legitimate user to sign under duress    | • Duress sign option (hidden alarm)<br>• Behavioral stress detection<br>• Environmental analysis<br>• Time-of-day usage patterns             | • Stress indicators in signing<br>• Unusual time/location<br>• Environmental anomalies<br>• Behavior change detection          | • Appear to grant access but limit functions<br>• Silent alert to trusted contacts<br>• Gradual session degradation<br>• Log evidence for authorities |
| <b>Sign Pattern Observation</b>     | Observing and mimicking user's signing patterns | • Privacy screen recommendations<br>• Pattern variation requirements<br>• Environmental awareness alerts<br>• Regular sign password rotation | • Shoulder surfing detection<br>• Camera detection in environment<br>• Login location anomalies<br>• Pattern similarity alerts | • Suggest changing sign password<br>• Temporarily increase security threshold<br>• Notify user of potential risk<br>• Offer privacy guidelines        |

## 2. API and Endpoint Security Threats

| Threat               | Description                                 | Prevention Measures                                                                                                      | Detection Methods                                                                                      | Response Plan                                                                                                                                  |
|----------------------|---------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>API Key Theft</b> | Unauthorized acquisition of API credentials | • Short-lived tokens<br>• Key rotation<br>• Scope-limited keys<br>• Environment-bound keys<br>• Context-aware validation | • Unusual API usage patterns<br>• Geographic anomalies<br>• Rate of requests<br>• Unexpected endpoints | • Immediate key revocation<br>• Audit of potentially accessed data<br>• Issue new keys with stricter controls<br>• Review application security |

|                                          |                                                              |                                                                                                                                                                                                                      |                                                                                                                                                                                                         |                                                                                                                                                                                                                   |
|------------------------------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Rate Limiting Bypass</b>              | Circumventing API rate limits through distributed requests   | <ul style="list-style-type: none"> <li>• IP reputation analysis&lt;br&gt;• Device fingerprinting&lt;br&gt;• Request pattern analysis&lt;br&gt;• Progressive rate limiting&lt;br&gt;• Global rate tracking</li> </ul> | <ul style="list-style-type: none"> <li>• Distributed request correlation&lt;br&gt;• Timing pattern analysis&lt;br&gt;• Endpoint access patterns&lt;br&gt;• Service impact monitoring</li> </ul>         | <ul style="list-style-type: none"> <li>• Dynamic rate limit adjustment&lt;br&gt;• Temporary IP range blocks&lt;br&gt;• CAPTCHA challenges&lt;br&gt;• Traffic prioritization</li> </ul>                            |
| <b>Insecure Direct Object References</b> | Accessing resources via manipulation of reference parameters | <ul style="list-style-type: none"> <li>• Indirect reference maps&lt;br&gt;• Strict authorization checks&lt;br&gt;• Resource-based permissions&lt;br&gt;• Reference obfuscation</li> </ul>                            | <ul style="list-style-type: none"> <li>• Unusual resource access patterns&lt;br&gt;• Sequential ID scanning&lt;br&gt;• Permission mismatch alerts&lt;br&gt;• Error rate monitoring</li> </ul>           | <ul style="list-style-type: none"> <li>• Block suspicious user sessions&lt;br&gt;• Review authorization logic&lt;br&gt;• Audit affected resources&lt;br&gt;• Patch vulnerability</li> </ul>                       |
| <b>Man-in-the-Middle Attack</b>          | Intercepting API communication between client and server     | <ul style="list-style-type: none"> <li>• Certificate pinning&lt;br&gt;• Mutual TLS&lt;br&gt;• HSTS implementation&lt;br&gt;• API request signing&lt;br&gt;• Traffic encryption</li> </ul>                            | <ul style="list-style-type: none"> <li>• Certificate validation failures&lt;br&gt;• TLS downgrade attempts&lt;br&gt;• Connection metadata changes&lt;br&gt;• Signature verification failures</li> </ul> | <ul style="list-style-type: none"> <li>• Force client application update&lt;br&gt;• Invalidate potentially compromised sessions&lt;br&gt;• Rotate encryption certificates&lt;br&gt;• User notification</li> </ul> |
| <b>Server-Side Request Forgery</b>       | Exploiting server to make unintended requests                | <ul style="list-style-type: none"> <li>• Request allowlisting&lt;br&gt;• Local DNS resolver&lt;br&gt;• Egress filtering&lt;br&gt;• HTTP proxy for outbound requests&lt;br&gt;• URL validation</li> </ul>             | <ul style="list-style-type: none"> <li>• Unexpected outbound connections&lt;br&gt;• DNS resolution anomalies&lt;br&gt;• Metadata server access attempts&lt;br&gt;• Internal service probing</li> </ul>  | <ul style="list-style-type: none"> <li>• Block malicious traffic patterns&lt;br&gt;• Server isolation&lt;br&gt;• Review vulnerable endpoints&lt;br&gt;• Update firewall rules</li> </ul>                          |
|                                          | Crafting                                                     | <ul style="list-style-type: none"> <li>• Query cost analysis&lt;br&gt;• Depth/complexity</li> </ul>                                                                                                                  | <ul style="list-style-type: none"> <li>• Query execution time monitoring&lt;br&gt;• Resource</li> </ul>                                                                                                 | <ul style="list-style-type: none"> <li>• Terminate expensive queries&lt;br&gt;• Refine</li> </ul>                                                                                                                 |

|                                         |                                                   |                                                                                         |                                                                                    |                                                                              |
|-----------------------------------------|---------------------------------------------------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| <b>GraphQL Query Complexity Attacks</b> | resource-intensive queries to overload the system | limits<br>• Timeout constraints<br>• Query whitelisting<br>• Resource allocation limits | utilization spikes<br>• Nested query depth analysis<br>• Database load correlation | complexity limits<br>• Cache common queries<br>• Implement persisted queries |
|-----------------------------------------|---------------------------------------------------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|------------------------------------------------------------------------------|

### 3. Data Protection and Privacy Threats

| Threat                            | Description                                                 | Prevention Measures                                                                                                                                                                                                                           | Detection Methods                                                                                                                                                                                         | Response Plan                                                                                                                                                                                                    |
|-----------------------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Unauthorized Data Access</b>   | Accessing user data without proper authorization            | <ul style="list-style-type: none"> <li>• Role-based access control&lt;br&gt;• Attribute-based access control&lt;br&gt;• Just-in-time access&lt;br&gt;• Data encryption&lt;br&gt;• Access audit trails</li> </ul>                              | <ul style="list-style-type: none"> <li>• Unusual access patterns&lt;br&gt;• Privilege escalation attempts&lt;br&gt;• Off-hours data access&lt;br&gt;• Bulk data retrieval</li> </ul>                      | <ul style="list-style-type: none"> <li>• Terminate suspicious sessions&lt;br&gt;• Investigate access patterns&lt;br&gt;• Adjust permissions&lt;br&gt;• Notify affected users if confirmed breach</li> </ul>      |
| <b>Data Leakage via Inference</b> | Extracting private information through pattern analysis     | <ul style="list-style-type: none"> <li>• Differential privacy techniques&lt;br&gt;• Aggregation of sensitive data&lt;br&gt;• Noise injection&lt;br&gt;• Minimum threshold response&lt;br&gt;• Rate limiting on analytics endpoints</li> </ul> | <ul style="list-style-type: none"> <li>• Unusual query patterns&lt;br&gt;• Systematic data collection&lt;br&gt;• Correlation attempts across datasets&lt;br&gt;• Statistical anomaly detection</li> </ul> | <ul style="list-style-type: none"> <li>• Restrict query capabilities&lt;br&gt;• Increase anonymization level&lt;br&gt;• Review data exposure points&lt;br&gt;• Adjust privacy budgets</li> </ul>                 |
| <b>Sign Pattern Dataset Theft</b> | Unauthorized access to training data or sign pattern corpus | <ul style="list-style-type: none"> <li>• Dataset encryption&lt;br&gt;• Access control to training data&lt;br&gt;• Anonymization of source data&lt;br&gt;• Federated learning approaches</li> </ul>                                            | <ul style="list-style-type: none"> <li>• Unusual dataset access&lt;br&gt;• Large data transfers&lt;br&gt;• API calls to training endpoints&lt;br&gt;• Model extraction</li> </ul>                         | <ul style="list-style-type: none"> <li>• Revoke access credentials&lt;br&gt;• Audit data access history&lt;br&gt;• Create new data encryption keys&lt;br&gt;• Review training infrastructure security</li> </ul> |

|                                    |                                                         |                                                                                                                                                                                                                                           |                                                                                                                                                                                                                       |                                                                                                                                                                                                           |
|------------------------------------|---------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                    |                                                         |                                                                                                                                                                                                                                           | attempts                                                                                                                                                                                                              |                                                                                                                                                                                                           |
| <b>Incomplete Data Deletion</b>    | Failure to completely remove user data upon request     | <ul style="list-style-type: none"> <li>• Comprehensive data mapping&lt;br&gt;• Deletion verification procedures&lt;br&gt;• Cascade deletion across systems&lt;br&gt;• Cryptographic erasure&lt;br&gt;• Regular deletion audits</li> </ul> | <ul style="list-style-type: none"> <li>• Data deletion audit failures&lt;br&gt;• Orphaned data references&lt;br&gt;• Inconsistent record counts&lt;br&gt;• Failed data subject requests</li> </ul>                    | <ul style="list-style-type: none"> <li>• Expedite complete deletion&lt;br&gt;• Review deletion procedures&lt;br&gt;• Audit all data stores&lt;br&gt;• Update data deletion processes</li> </ul>           |
| <b>Unintended Data Linkability</b> | Connecting anonymized data back to individuals          | <ul style="list-style-type: none"> <li>• Separation of identifiers&lt;br&gt;• K-anonymity implementation&lt;br&gt;• Metadata scrubbing&lt;br&gt;• Regular privacy impact assessments</li> </ul>                                           | <ul style="list-style-type: none"> <li>• Cross-dataset correlation attempts&lt;br&gt;• Unusual pattern matching queries&lt;br&gt;• Attempts to join separate datasets&lt;br&gt;• Privacy budget exhaustion</li> </ul> | <ul style="list-style-type: none"> <li>• Enhance anonymization techniques&lt;br&gt;• Introduce additional noise&lt;br&gt;• Review data separation practices&lt;br&gt;• Update privacy controls</li> </ul> |
| <b>Cross-Device Data Leakage</b>   | Sensitive data inadvertently shared across user devices | <ul style="list-style-type: none"> <li>• Device-specific encryption&lt;br&gt;• Data classification controls&lt;br&gt;• Sync controls by data sensitivity&lt;br&gt;• Selective content synchronization</li> </ul>                          | <ul style="list-style-type: none"> <li>• Unusual sync patterns&lt;br&gt;• Device authorization anomalies&lt;br&gt;• Sensitive data access across devices&lt;br&gt;• Unauthorized device registration</li> </ul>       | <ul style="list-style-type: none"> <li>• Temporary sync suspension&lt;br&gt;• Audit synchronized data&lt;br&gt;• Device authorization reset&lt;br&gt;• Update cross-device policies</li> </ul>            |

## 4. Webhook and Integration Security Threats

| Threat         | Description   | Prevention Measures                                                                                             | Detection Methods                                                                                            | Response Plan                                                                                              |
|----------------|---------------|-----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>Webhook</b> | Capturing and | <ul style="list-style-type: none"> <li>• Unique event IDs&lt;br&gt;• Timestamp validation&lt;br&gt;•</li> </ul> | <ul style="list-style-type: none"> <li>• Duplicate event processing attempts&lt;br&gt;• Timestamp</li> </ul> | <ul style="list-style-type: none"> <li>• Reject duplicate payloads&lt;br&gt;• Alert integration</li> </ul> |

|                                    |                                                              |                                                                                                                                                  |                                                                                                                                          |                                                                                                                   |
|------------------------------------|--------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>Replay Attacks</b>              | replaying webhook payloads                                   | One-time signature tokens<br>• Idempotency keys<br>• TTL on webhook events                                                                       | anomalies<br>• Signature reuse detection<br>• Out-of-sequence events                                                                     | owner<br>• Review webhook security<br>• Reset webhook secrets                                                     |
| <b>Webhook URL Hijacking</b>       | Changing webhook destination to attacker-controlled endpoint | • URL change verification process<br>• Multi-factor approval for URL changes<br>• Gradual rollout of URL changes<br>• URL ownership verification | • Unusual URL change patterns<br>• Changes from unusual locations<br>• Changes outside business hours<br>• High-risk destination domains | • Revert to previous URL<br>• Suspend webhook delivery<br>• Notify integration owner<br>• Review recent data sent |
| <b>Weak Webhook Authentication</b> | Insufficient validation of webhook source                    | • HMAC signature validation<br>• Mutual TLS<br>• API key rotation<br>                                                                            |                                                                                                                                          |                                                                                                                   |